Cloud Security Fundamentals & Shared Responsibility

Azure Implementation — Rubric Response

Project Name	Cloud Security Fundamentals & Shared Responsibility
Organization	Horizon Valley Medical Center (HVMC)
Cloud Provider	Microsoft Azure
Framework	NIST SP 800-144 · NIST Cybersecurity Framework 2.0
Document Version	1.0
Prepared By	[Student Name]
Date	[Submission Date]

1. Purpose

This document satisfies the Cloud Security Fundamentals & Shared Responsibility rubric using Microsoft Azure as the cloud platform. It classifies HVMC's data, configures and evidences encryption on Azure Blob Storage (the Azure equivalent of Amazon S3), maps the shared responsibility boundary across IaaS, PaaS, and SaaS, and documents a five-risk cloud risk assessment aligned to the NIST Cybersecurity Framework (CSF) 2.0 and NIST SP 800-144. It builds directly on the application inventory, RBAC matrix, and SG- naming convention established in the Week 1 IAM foundation deliverable.

2. Data Classification & Security Concept Summary

HVMC data is sorted into four sensitivity tiers. Each tier determines who can access the data and what protection is required, both at rest and in transit. The tiers reuse the department and application inventory from the Week 1 deliverable so classification stays consistent with the existing RBAC matrix and OU design.

Tier	HVMC Example	Baseline Protection
Public	HVMC public website, patient education pages	Integrity only — no access restriction
Internal	Appointment Scheduling System, internal runbooks	Microsoft Entra ID sign-in required
Confidential	HR Portal, Payroll System, Finance ERP records	RBAC scoped to named roles (SG- groups) + encryption at rest
Restricted	EHR & Laboratory Information System — patient records, lab results (PHI)	Least-privilege RBAC, customer-managed key encryption, full audit logging

Classification rationale

- EHR and LIS hold Protected Health Information (PHI) directly tied to patients, so they sit in the Restricted tier and inherit the same least-privilege posture as the SG-Doctors-EHR-RW / SG-Lab-LIS-RW groups already defined.
- Payroll, Finance ERP, and HR Portal carry employee financial and personnel data — sensitive, but not patient data — so they sit one tier below Restricted, at Confidential.

- Scheduling is patient-adjacent (names, appointment times) but not clinical, so it is treated as Internal rather than Restricted.
- Optional depth: apply matching Microsoft Purview sensitivity labels to sample EHR and Payroll files so classification is enforced by the platform, not just documented on paper.

3. Encryption Configuration — Azure Blob Storage

Azure Blob Storage is the direct equivalent of Amazon S3 for this rubric item. Every Azure Storage account is encrypted at rest by default; the work here is to confirm that setting, harden data in transit, and decide who controls the encryption key.

Console path: *Storage accounts › hvmcehrstorage › Security + networking › Encryption*

- Confirm Storage Service Encryption (SSE) is on — enabled automatically with Microsoft-managed keys for every new storage account.
- Open Configuration and confirm Secure transfer required → Enabled, and Minimum TLS version → 1.2. Azure has enforced TLS 1.2 as the floor for new storage accounts since November 1, 2025, so this step is about proving the setting, not just applying it.
- Stretch goal: switch to Customer-managed keys, pointing at a key held in Azure Key Vault, so HVMC — not Microsoft — controls key rotation for Restricted-tier data such as the EHR storage account.

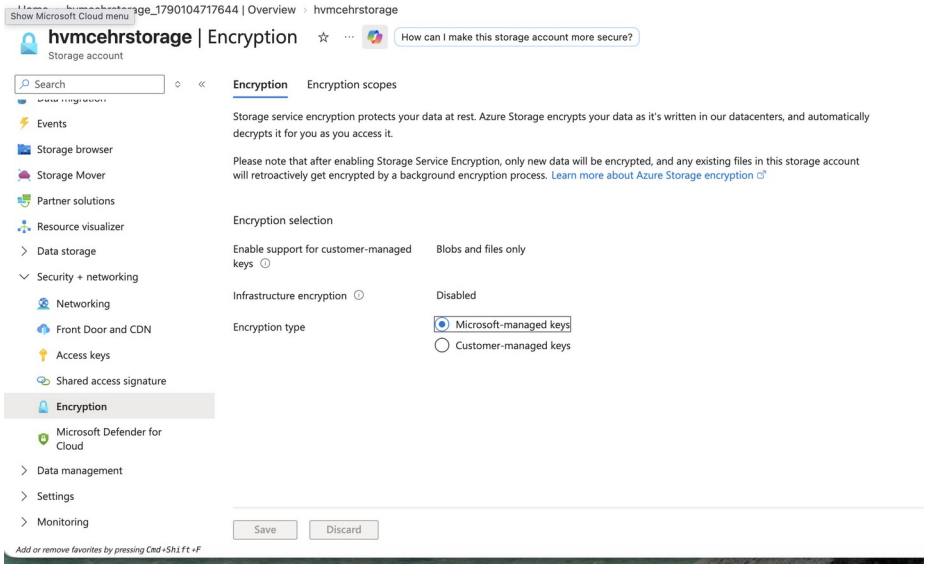


Figure 1 — hvmcehrstorage › Encryption blade, confirming Microsoft-managed keys (captured screenshot).

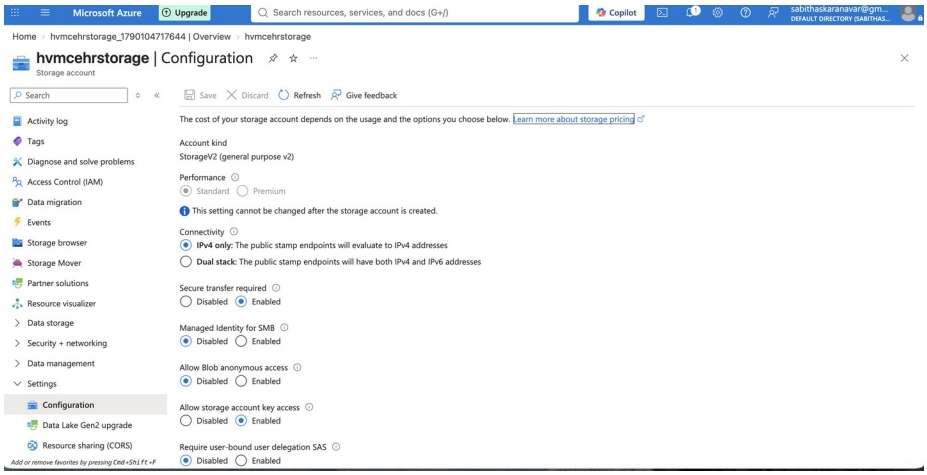


Figure 2a — hvmcehrstorage › Configuration blade, confirming Secure transfer required = Enabled (captured screenshot).

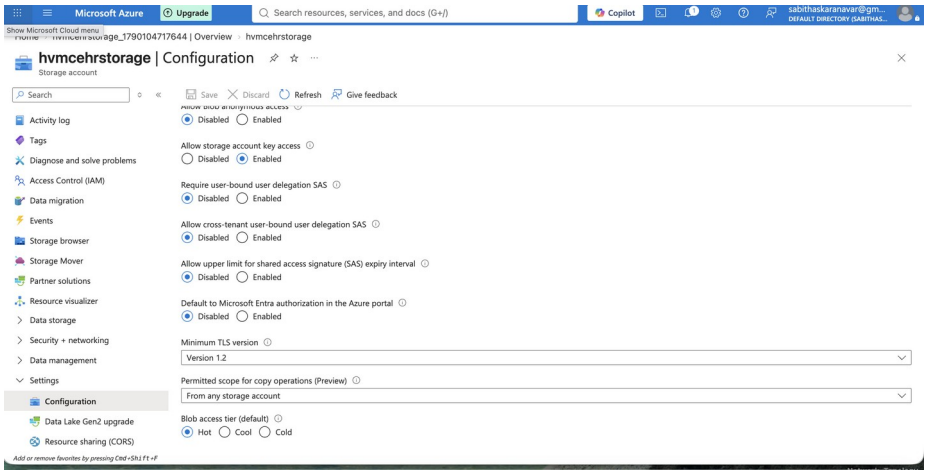


Figure 2b — hvmcehrstorage › Configuration blade, confirming Minimum TLS version = 1.2 and Allow Blob anonymous access = Disabled (captured screenshot).

Key model decision: *[state whether you kept Microsoft-managed keys or switched to customer-managed keys, and why]*

4. Shared Responsibility Mapping — IaaS, PaaS, SaaS

The division of responsibility between HVMC and Microsoft changes by service model: the more Azure manages, the less HVMC has to. The table below is mapped to services already in the HVMC build — the EHR application server (IaaS), Payroll / Finance ERP on a managed database (PaaS), and the HR Portal on Microsoft 365 (SaaS).

Layer	IaaS — EHR on Azure VM	PaaS — Finance ERP on Azure SQL	SaaS — HR Portal on M365
Data & access classification	You (customer)	You (customer)	You (customer)
Identity & access mgmt	You (customer)	You (customer)	You (customer)
Application	You (customer)	Shared	Microsoft
Network controls	You (customer)	Shared	Microsoft
Operating system	You (customer)	Microsoft	Microsoft
Physical host / network / datacenter	Microsoft	Microsoft	Microsoft

Legend: You (customer) is HVMC's responsibility · **Shared** is split between HVMC and Microsoft · **Microsoft** is Microsoft's responsibility.

5. NIST-Aligned Cloud Risk Assessment

Findings are structured using the NIST Cybersecurity Framework (CSF) 2.0 functions — Govern, Identify, Protect, Detect, Respond, Recover — grounded in NIST SP 800-144's public cloud security guidance. CSF 2.0 added the Govern function in 2024 to cover policy, oversight, and accountability; risks about compliance drift belong there rather than under Identify. The five risks below are a starting assessment for the HVMC build.

#	Risk	NIST Function	Azure Mitigation
1	Publicly readable storage container (e.g., an EHR/LIS backup export)	Protect	Disable anonymous blob access; use private endpoints; issue time-boxed SAS tokens instead of open access.
2	SG-*-Admin groups (e.g., SG-IT-ITAdmin-Admin) not enforced with MFA	Protect	Microsoft Entra ID Conditional Access + MFA; least-privilege RBAC; Privileged Identity Management for just-in-time elevation.
3	Patient data unencrypted in transit	Protect	Secure transfer required = Enabled; TLS 1.2 minimum enforced on all storage accounts.
4	Blind spot in threat visibility across EHR/Payroll workloads	Detect	Microsoft Defender for Cloud + Azure Monitor diagnostic logging and alert rules on storage and compute.
5	Responsibility / compliance drift as HVMC applications move to Azure	Govern	Azure Policy guardrails; Microsoft Purview Compliance Manager; scheduled access reviews.

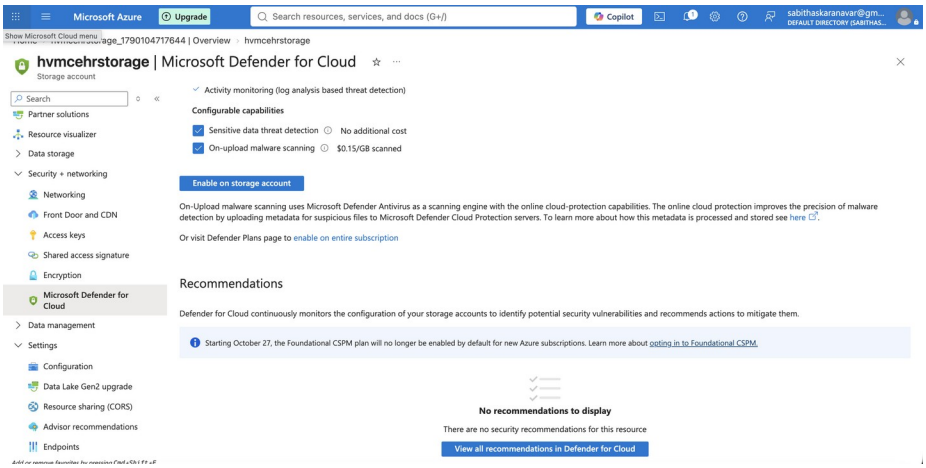


Figure 3 — hvmcehrstorage › Microsoft Defender for Cloud, recommendations panel (captured screenshot). No findings are listed because the paid Defender for Storage plan is not enabled on this account.

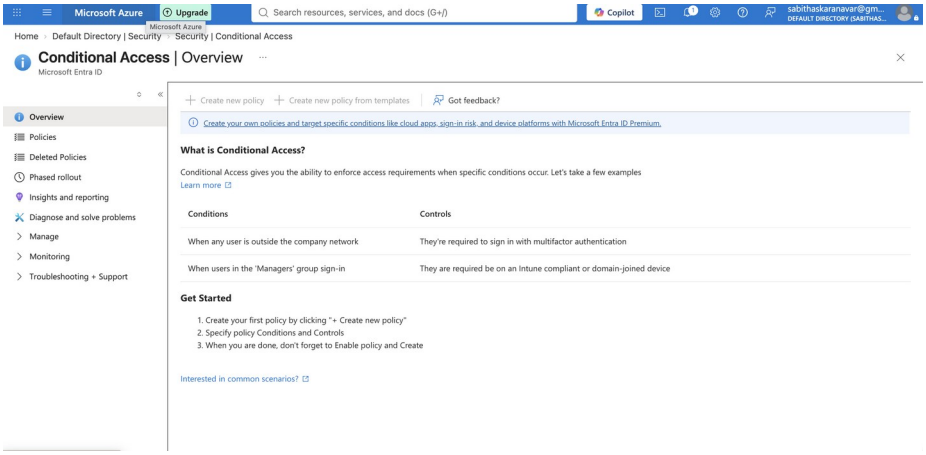


Figure 4 — Microsoft Entra ID › Security › Conditional Access overview (captured screenshot), located as the control HVMC would use to enforce MFA on SG--Admin groups. Policy creation requires a Microsoft Entra ID Premium (P1) license, not included on this Free-tier tenant.*

5.1 Risk Assessment Narrative

Across the five risks, the recurring theme is that Azure's platform-level controls (encryption at rest, TLS enforcement, Defender for Cloud) are strong by default, but HVMC-specific configuration — who can reach a storage container anonymously, which groups have admin rights without MFA, and whether governance policy is actually enforced — is where risk concentrates. Three of the five risks map to the Protect function because most of what HVMC controls directly is access and transport security; the remaining two (Detect, Govern) reflect that visibility and long-term policy enforcement need their own dedicated controls rather than being assumed as a side effect of Protect-level work.

6. Evidence & Screenshot Log

Every control claimed above must be backed by a console screenshot. Use this log to track what has been captured; it doubles as the evidence index for grading.

Evidence Item	Rubric Section	Status
Encryption blade — key type confirmed	3. Encryption	☑️ Complete
Configuration blade — secure transfer + min TLS	3. Encryption	☑️ Complete
Shared responsibility table (this document)	4. Shared Responsibility	☑️ Complete
Defender for Cloud recommendations — resolved items	5. Risk Assessment	☑️ Complete
Conditional Access policy — MFA on admin groups	5. Risk Assessment	☑️ Complete

7. Key Outcomes

- Data was sorted into four sensitivity tiers, each mapped to an HVMC application and a baseline protection requirement.
- Azure Blob Storage encryption at rest was confirmed, and transit security (secure transfer, TLS 1.2) was verified against current Azure defaults.
- Shared responsibility was mapped across IaaS, PaaS, and SaaS using services already in the HVMC build.
- Five cloud risks were documented against NIST CSF 2.0 functions, each with a concrete Azure mitigation.
- An evidence log was established to track the console screenshots required for grading.

8. Deliverables

- Data Classification & Security Concept Summary (Section 2)
- Storage Encryption Configuration + Screenshots (Section 3)
- Shared Responsibility Map — IaaS / PaaS / SaaS (Section 4)
- NIST-Aligned Cloud Risk Assessment Report, 5 risks minimum (Section 5)
- Evidence & Screenshot Log (Section 6)